

Campagne de Vishing et vol de données SaaS

Le 01/04/2026, Mandiant a publié une analyse sur l'expansion des vols de données ciblant les environnements SaaS (Microsoft 365, Salesforce).

Cette campagne, attribuée au groupe ShinyHunters, utilise le "Vishing" (Phishing vocal) pour contourner les protections classiques.

Qu'est-ce que le Vishing dans ce contexte ?

Les attaquants appellent directement un employé en se faisant passer pour un technicien du service informatique. Ils exploitent la pression psychologique pour guider la victime vers un portail de connexion factice. L'objectif est de capturer non seulement l'identifiant et le mot de passe, mais aussi le jeton de session. Une fois ce jeton récupéré, l'attaquant peut contourner l'authentification multifacteur (MFA) car il "rejoue" une session déjà validée.

Contrairement à une faille technique, cette méthode repose sur l'ingénierie sociale et la manipulation de l'identité. Microsoft et Mandiant observent que ces accès sont souvent revendus à des tarifs élevés sur des forums spécialisés (Initial Access Brokers).

Pour se protéger, il est recommandé de migrer vers des méthodes MFA résistantes au phishing, comme les clés de sécurité FIDO2. Microsoft suggère aussi de renforcer les politiques d'Accès Conditionnel dans Microsoft Entra ID pour bloquer les connexions suspectes.

Cette menace démontre que la sécurité du Cloud dépend désormais autant de la vigilance humaine que de la robustesse des protocoles.

Sources :

<https://cloud.google.com/blog/topics/threat-intelligence/defense-against-shinyhunters-cybercrime-saas/?hl=en>

<https://www.rapid7.com/blog/post/tr-initial-access-broker-shift-high-value-targets-premium-pricing/>

<https://cloud.google.com/blog/topics/threat-intelligence/expansion-shinyhunters-saas-data-theft/?hl=en>